

CASO DE ESTUDIO

DataFlow Labs es una startup de tecnología fundada hace 2 años en Bogotá. Desarrollan una plataforma SaaS de análisis de datos empresariales que permite a sus clientes corporativos cargar, procesar y visualizar grandes volúmenes de información financiera y operativa.

La empresa cuenta actualmente con **35 empleados** distribuidos así:

- **Equipo de Producto y Desarrollo** (12 personas): desarrollan y mantienen la plataforma.
- **Equipo de Datos e IA** (6 personas): diseñan los modelos analíticos y tienen acceso directo a las bases de datos de entrenamiento.
- **Equipo Comercial y Customer Success** (8 personas): gestionan clientes, contratos y demostraciones de la plataforma.
- **Equipo de Operaciones y TI** (4 personas): administran la infraestructura, servidores y accesos del sistema.
- **Equipo Legal y Finanzas** (3 personas): manejan contratos, facturación y cumplimiento regulatorio.
- **Directivos (C-Level)** (2 personas): CEO y CTO, con visibilidad global del negocio.

Activos de información críticos de DataFlow Labs:

ID	Activo	Descripción
A1	Base de datos de clientes	Nombres, contratos, datos de contacto, historial de compras
A2	Código fuente de la plataforma	Repositorio Git con toda la lógica del producto
A3	Datos financieros internos	Nómina, presupuestos, estados de resultados
A4	Datos de entrenamiento de IA	Datasets cargados por clientes para entrenar modelos
A5	Panel de administración del sistema	Consola de control de servidores, configuración y accesos

A6	Contratos y documentos legales	Acuerdos de confidencialidad, contratos con clientes y proveedores
A7	Dashboard de métricas del negocio	KPIs de ventas, uso de la plataforma, retención de clientes
A8	Sistema de tickets de soporte	Solicitudes e incidencias reportadas por clientes

CLASIFICACIÓN DE ACTIVOS

Para cada uno de los 8 activos listados anteriormente, completen la siguiente tabla asignando:

- **Nivel de clasificación:** Público / Interno / Confidencial / Crítico
- **Justificación breve:** ¿Por qué le asignaron ese nivel?
- **Impacto si se filtra:** Bajo / Medio / Alto / Catastrófico

ID	Activo	Nivel de clasificación	Justificación	Impacto si se filtra
A1	Base de datos de clientes			
A2	Código fuente			
A3	Datos financieros internos			
A4	Datos de entrenamiento de IA			
A5	Panel de administración			
A6	Contratos y documentos legales			
A7	Dashboard de métricas			
A8	Sistema de tickets de soporte			

1. ¿Qué activo consideran el más crítico para la supervivencia del negocio y por qué?

DEFINICIÓN DE ROLES Y PROPIETARIOS

Para cada activo, identifiquen quién debería ser el **Propietario** y quién el **Custodio**, **Usuarios** según los equipos descritos en el caso.

Recuerden:

- **Propietario:** quien tiene la responsabilidad de negocio sobre ese dato y decide quién puede acceder.
- **Custodio:** quien lo administra técnicamente (generalmente TI).
- **Usuario:** quien lo consulta o usa en su trabajo diario.

ID	Activo	Propietario (equipo/cargo)	Custodio (equipo/cargo)	Usuarios típicos
A1	Base de datos de clientes			
A2	Código fuente			
A3	Datos financieros internos			
A4	Datos de entrenamiento de IA			
A5	Panel de administración			
A6	Contratos y documentos legales			
A7	Dashboard de métricas			
A8	Sistema de tickets de soporte			

TABLA DE CONTROL DE ACCESO (MATRIZ RBAC)

Usen el modelo **RBAC (Role-Based Access Control)** para diseñar la matriz de permisos de DataFlow Labs.

Convención de permisos:

- **L** = Solo lectura (can Read)
- **E** = Lectura y escritura (can Edit)
- **A** = Acceso total con administración (Admin)
- **—** = Sin acceso

Completen la siguiente matriz cruzando cada equipo con cada activo:

Activo → / Equipo ↓	A1 Clientes	A2 Código	A3 Finanzas	A4 Datos IA	A5 Panel Admin	A6 Contratos	A7 Métricas	A8 Soporte
Desarrollo								
Datos e IA								
Comercial / CS								
Operaciones / TI								
Legal / Finanzas								
CEO / CTO								

1. ¿Se aplica el principio de **privilegio mínimo**?
2. ¿Debería el CEO tener acceso total a todos los activos? Argumenten su decisión.

DIAGRAMA DEL ESQUEMA DE CONTROL DE ACCESO

Con base en la matriz que construyeron, elaboren un diagrama que represente visualmente el esquema de control de acceso de DataFlow Labs.

- El diagrama debe mostrar los activos A1 a A8 como bloques organizados según su nivel de clasificación.
- Los equipos y roles de la empresa se representan como entidades separadas que se conectan a dichos activos mediante flechas, indicando en cada flecha el tipo de permiso correspondiente (L, E o A).
- Finalmente, los activos clasificados como Críticos o Confidenciales deben agruparse dentro de una zona de alta seguridad que los separe visualmente del resto.

Pueden hacerlo a mano, en draw.io, Lucidchart, Miro, o cualquier herramienta de diagramación que prefieran.

1. ¿Identificaron algún error o inconsistencia en su matriz que no habían notado antes?

ESCENARIOS DE AMENAZA

Evalúen los siguientes escenarios aplicados al contexto de DataFlow Labs. Para cada uno, respondan:

- **¿El esquema de control de acceso que diseñaron lo habría prevenido?**
- **¿Qué control específico lo hubiera evitado o mitigado?**

Escenario 1 — El empleado curioso Un desarrollador del equipo de producto nota que puede acceder al módulo de nómina dentro del sistema interno porque nadie configuró restricciones en ese directorio. Descarga el archivo de salarios de todos los empleados y lo comparte con un compañero.

- ¿Su matriz lo habría prevenido?
- ¿Qué control de acceso específico falla aquí?
- ¿Qué corrección aplicarían?

Escenario 2 — La cuenta olvidada Una diseñadora UX trabajó 6 meses en DataFlow Labs y renunció. Tres meses después de su salida, su cuenta de usuario sigue activa. Un atacante externo que obtuvo sus credenciales por phishing accede al repositorio de código fuente usando esa cuenta.

- ¿Su esquema contempla la gestión del ciclo de vida de los usuarios?
- ¿Qué proceso debería existir para evitar esto?

- ¿Qué tipo de control es este: preventivo, detectivo o correctivo?

Escenario 3 — El cliente con demasiado acceso Un cliente corporativo de DataFlow Labs contacta al equipo de Customer Success para solicitar ayuda con su dashboard. El asesor comercial, para agilizar el soporte, le comparte sus propias credenciales de acceso al panel de administración. El cliente, sin mala intención, navega por secciones a las que no debería tener acceso y descarga datos de otro cliente.

- ¿Qué principio de control de acceso se violó?
- ¿Qué mecanismo técnico y organizacional hubiera prevenido esta situación?
- ¿Quién es responsable del incidente: el asesor, la empresa, el cliente?